BridgeWitness

Real-time detection of cross-chain bridge exploits | CSB-01

THE PRINCIPLE

Signatures can be stolen. Conservation cannot: every destination release must consume a verified, unspent source deposit.

THE PRODUCT

An independent bridge monitor that connects exact backing checks, explainable alerts and evidence an operator can re-run.

THE DEMO

Public Nomad + Ronin attack replays, a seeded adversarial simulation, and evidence from a controlled two-chain gate demonstration.

THE AMBITION

Move from discovering theft after settlement to holding unsupported releases before execution on integrated bridges.

A valid signature is permission. A verified deposit is backing.

Basis: project PRD; generated history, detection and evidence fixtures.

Bridges trust permission. Attackers exploit the gap.

The critical failure: an approved withdrawal can still be economically unbacked.

THE FAILURE MODE

A destination contract accepts a message or signer quorum while the matching source deposit is missing, already spent, or inconsistent.

THE HUMAN LIMIT

Operators must reconcile two chains, uncertain finality and many recipients while an exploit continues. Manual review starts too late for rapid settlement.

THE SCALE

On 2 August 2022, Chainalysis estimated $2B stolen across 13 bridge hacks; bridges accounted for 69% of crypto stolen that year to date.

THE REQUIRED RESPONSE

Ingest live or replayed transactions; identify pair mismatches, volume spikes and signer anomalies; deliver a risk-ranked suspected exploit type.

Problem statement: detect unsupported cross-chain value movement early, explain it, and enable a proportionate response.

External: Chainalysis, 2 Aug 2022 [S1]. Brief: CSB-01 in BridgeWitness-PRD.md.

Two theft patterns. One broken invariant.

Our replay explains why signatures and volume thresholds cannot be the final authority.

RONIN: LOW EVENT COUNT

Two attack releases, only 115 seconds apart. Our configured velocity detector flags 0/2; the backing rule flags both.

NOMAD: COPYCAT FAN-OUT

382 attack releases across 167 transactions and 279 recipients. The first velocity flag arrives at +2,986 seconds: 49 min 46 sec.

THE COST OF WAITING

Before that Nomad volume flag, 17 releases total about $23.59M in historical dataset value. This is observed replay exposure, not money saved.

OUR DESIGN RESPONSE

Use exact authorization and consumption rules for exploit verdicts. Use behavioral signals to rank and explain the developing incident.

The decisive question is whether the release is backed, even when its signatures look legitimate.

Local: detection.json; history.json; PRD measured-results table. Values cover the dataset subset.

Reconcile first. Explain every decision.

Three required signals, one transparent decision flow.

1. CONSERVATION LEDGER

Match route + message ID; validate source contract, amount, recipient and remaining authorization. Reject replay and over-consumption with exact integer arithmetic.

2. VELOCITY + SIGNER FORENSICS

Compare recent withdrawal activity with route history. Check signer membership, quorum and duplication; flag suspicious repeated signer sets when metadata exists.

3. ACTIONABLE ALERTS

Name the suspected exploit, show the violated rule, expose the 0-100 priority breakdown, and correlate related releases into an incident with USD exposure.

4. EVIDENCE + RESPONSE

Package the decision for browser recomputation. In the integrated gate design, a rule violation can hold a release; behavioral warnings alone cannot.

Signals advise. Deterministic rules decide.

Local: detect/analyze.ts, classify.ts, velocity.ts; verify/accounting.ts; data/monitor.ts.

No release without real, unspent backing.

The accounting rule is exact; observability determines whether we can apply it.

MATCH THE AUTHORIZATION

Pin source/destination chain, bridge contract, token and message. Confirm the intended recipient and exact amount under the configured route semantics.

TRACK CONSUMPTION

A deposit creates a bounded authorization. Earlier releases consume it; reusing the message cannot create a second entitlement to the same funds.

CHECK THE BOUND

Prior consumption + requested release must stay within verified authorization. Token decimals and fixed-fee rules are handled in exact common units.

NAME THE BLIND SPOT

If source coverage is incomplete, behind or unhealthy, say unknown. Absence from an incomplete event feed does not prove absence on-chain.

Same root check, multiple attacks: fake deposits, unbacked releases, replay, amount tampering and recipient substitution.

Local: verify/accounting.ts; PRD backing-rule and watermark definitions. Invariant prior art: [S2].

What makes the prototype worth remembering.

A defensible combination of evidence, operational judgment and reproducible evaluation.

EVIDENCE YOU CAN CHALLENGE

The browser rechecks canonical JSON hash, supplied block headers, transaction/receipt inclusion and accounting. Twelve reference bundles reproduce the expected results.

HONEST UNCERTAINTY

Unknown is a first-class verdict. Lag or missing coverage is visible instead of being disguised as an exploit or a safety guarantee.

CONTAINMENT WITH LIMITED DISRUPTION

A route hold is demonstrated on local chains. Message-to-route-to-verifier escalation is the proposed response model, with broader gate behavior still pending.

THE TRADEOFF IS VISIBLE

Counterfactual replay compares loss and disruption under five response policies. The narrow policy can lose more; the interface makes that visible.

The differentiator is an auditable decision-to-response workflow, not a claim that cross-chain matching is new.

Local: verifier, evidence fixtures, counterfactual.ts; Architecture.tsx status table; research [S2].

Strong results, with their boundaries attached.

Historical replay + deterministic simulation + reference evidence artifacts.

382 / 382 NOMAD RELEASES

Backing violations identified from the first offending release in the replay. 0/193 normal releases flagged in the selected 1-2 August window.

2 / 2 RONIN RELEASES

Backing rule flags both historical attack releases. The configured replay volume detector flags neither.

6 ATTACKS + 2 CONTROLS

All six injected attack scenarios receive the expected exploit type. A backed whale and honest traffic burst produce no exploit verdict.

12 / 12 EVIDENCE BUNDLES

Generated fixtures record browser/Python agreement. Reference engine latency: p50 0.82 ms; p99 2.60 ms across 300 local pairs.

Replay matching validates implementation against these labels; it does not establish independent or universal detection accuracy.

Local: detection.json, history.json, evidence.json, model.json; fixture-builder assertions.

Give the judges three things to challenge.

A 90-second sequence using the existing console and prepared reference exhibits.

00-25s: STOLEN-KEY DRAIN

Open Monitor on the seeded simulation. Seek to key compromise + drain: show valid quorum, missing backing, signer behavior and the explicit priority breakdown.

25-45s: THE HONEST BURST

Show nine backed transfers causing a volume advisory. No exploit verdict: unusual activity alone is insufficient to justify containment.

45-70s: TAMPER WITH EVIDENCE

Open a supplied Evidence bundle; run browser verification. Change an amount and compare with the expected digest/accounting result.

70-90s: HISTORICAL + GATE EXHIBITS

Switch to the Nomad replay and show the incident exposure. Present the reference local-chain report: unbacked execution blocked; healthy settlement completed.

Suggested closing challenge: can the judges make us mistake a blind spot or an honest burst for an exploit?

Routes: /console/monitor, /console/evidence/:sha, /console/replay. Local gate exhibit: evidence.json.

Protect value without stopping every user.

Benefits map to specific beneficiaries and measurable operational outcomes.

BRIDGE OPERATORS

Get an exact failure reason and incident-level exposure instead of manually reconciling hundreds of transaction alerts. Evidence supports faster triage.

USERS + LIQUIDITY PROVIDERS

On integrated bridges, holding unsupported releases could limit reserve depletion. Healthy routes can continue where the selected scope permits.

SECURITY TEAMS + AUDITORS

Receive portable evidence they can re-run and compare against the original digest; inspect which facts and trust assumptions produced the verdict.

SUCCESS METRICS

Time to first correct verdict; loss before containment; legitimate transfers delayed; exploit versus advisory false alerts; evidence reproduction rate.

Measure both loss avoided in modeled scenarios and the cost imposed on legitimate transfers.

Local: incident monitor, counterfactual UI, verifier and PRD evaluation plan. Benefits are proposed outcomes.

A practical stack for exact decisions.

Existing frontend in this workspace; backend and local gate demonstrated in the reference project.

OPERATOR INTERFACE

React 18 + TypeScript + Vite; React Router; Three.js / React Three Fiber for cross-chain flow inspection; Framer Motion + Lenis for presentation.

DETECTION + STATE

TypeScript BigInt accounting and replay signals today. Reference backend: Python + FastAPI; SQLite WAL for persisted events and deterministic reconciliation.

CHAIN + CRYPTOGRAPHY

EVM JSON-RPC and finalized-block scans; Solidity gate on two local Ganache chains. RLP, Keccak, Merkle-Patricia inclusion checks and canonical-JSON SHA-256.

DATA + TRIAGE

SHA-256-pinned XChainWatcher CSVs; deterministic simulation seed 2410. Reference Isolation Forest is optional advisory triage, with no containment authority.

Exact integer rules handle money. Cryptography makes supplied evidence inspectable. ML supplies bounded context.

Local: web/package.json, verify/*, fixtures; HANDOFF.md; BridgeWitness-ML-Reliability.md.

The hard parts are separated and testable.

What exists, what is demonstrated elsewhere, and what remains.

BUILT HERE

Replay monitoring, three signal panels, risk-ranked exploit alerts, incident preview, browser verifier, counterfactual policy explorer and generated data fixtures.

REFERENCE DEMONSTRATION

Python engine + FastAPI, finality-tag scanner and local Solidity route hold. Artifacts show blocked unbacked execution and completed healthy settlement.

NEXT INTEGRATION

Connect backend events to the frontend via SSE; add a public-testnet adapter; implement complete state-proof evidence and gate delay/escalation semantics.

DEPLOYMENT CONDITIONS

Trusted/cross-checked headers and coverage, resilient RPC access, audited contracts and guardian policy. Account for finality and RPC delay before choosing the hold window.

A replay demo is feasible now; public-network enforcement needs additional integration and independent security review.

Local: data/index.ts fixture mode; docs/Architecture.tsx; evidence.live; PRD capability status.

Start with one operator and one route.

A focused adoption hypothesis, with no invented customers, revenue or pricing.

FIRST CUSTOMER

An EVM bridge operator with explicit deposit/release semantics and an incident-response owner. Start with one supported lock/mint or burn/release route.

LOWER-FRICTION PILOT

Run read-only beside existing infrastructure. Compare alerts with operator review, verify evidence and measure unknown coverage before granting hold authority.

PROPOSED BUSINESS MODEL

Managed monitoring subscription priced by supported routes and operational coverage; integration/support for evidence and gate workflows. Pricing is unvalidated.

WHY PAY / HOW TO VALIDATE

Potential value: less reconciliation work and reduced unsupported exposure. Interview operators, collect pilot workload data and confirm willingness to pay.

First prove that an operator trusts the evidence and uses it; then evaluate optional enforcement.

Commercial plan: team proposal. No customer interviews, paid pilots or unit-economics evidence claimed.

Ship evidence before broader authority.

Milestone gates, rather than unsupported calendar promises.

M1: END-TO-END TESTNET

Connect the UI and backend on one public-testnet route. Demonstrate healthy transfer, missing backing, replay and observer-gap behavior with public transaction references.

M2: STRONGER EVIDENCE

Implement verified deposit commitments and storage exclusion proofs; improve header/finality trust. Distinguish supplied-header consistency from canonical-chain assurance.

M3: INDEPENDENT VALIDATION

Use separately adjudicated normal traffic and more incidents. Test reorgs, RPC gaps, malicious observers, baseline behavior and sustained load.

M4: CONTROLLED OPERATOR PILOT

Begin read-only. Add audited gate integration only after latency, false holds, guardian availability and recovery procedures meet operator-agreed targets.

Broaden chains and bridge models after one route is demonstrably correct and operationally useful.

Roadmap synthesized from PRD, HANDOFF and ML reliability contract; milestones not completed claims.

Trust is earned by exposing the assumptions.

These boundaries belong in the pitch, not hidden after a judge asks.

DATASET LIMIT

Historical labels derive from matching rules; replay coverage is assumed complete. Public CSVs have no signer data. Dollar values are historical dataset values.

PROOF LIMIT

Current evidence proves internal consistency and inclusion under supplied headers. State non-deposit proof integration and stronger consensus trust remain roadmap.

DEPLOYMENT LIMIT

UI defaults to fixtures; gate artifacts use local, unaudited contracts. No public-chain prevention, recovered funds or production uptime is claimed.

MODEL LIMIT

Reference forest warning recall is 9/384 = 2.34% on the held-out split. It advises only; it cannot override accounting or authorize containment.

We can defend every demonstrated result without claiming that two incidents predict every future exploit.

Local: SiteLayout.tsx NON_CLAIMS; model.json; reliability contract; architecture status.

Every withdrawal should carry its witness.

BridgeWitness: exact backing checks, visible uncertainty and inspectable response.

THE PROBLEM WE SOLVE

A bridge can approve a release that was never properly backed. Valid signatures and dramatic volume are insufficient evidence of legitimacy.

THE WORKING PROTOTYPE

A required three-signal dashboard, reproducible public-attack replay, controlled attack scenarios and independently re-executable supplied evidence.

THE REASON TO REMEMBER US

We show why a release fails, when the observer cannot decide, and what a narrower or broader response would cost.

THE NEXT ASK

A design partner for one EVM route: read-only validation first, independently reviewed evidence next, and audited selective enforcement after that.

Do not just ask who signed. Ask what backs the release.

Pitch positioning based on demonstrated prototype and explicitly labeled roadmap.

The project in submission-ready language.

Use these paragraphs for the hackathon application or abstract.

PROBLEM STATEMENT

Cross-chain bridges can release destination assets without a legitimate, unspent source authorization. Compromised signers, replayed messages and inconsistent transfers exploit this gap while operators face fragmented chain data and fast outflow.

PROPOSED SOLUTION

BridgeWitness reconciles each release against exact source backing, adds velocity and signer context, and emits an explained exploit-priority alert. It exposes incomplete coverage instead of forcing a verdict and packages the supplied evidence for browser verification.

EXPECTED IMPACT

Operators gain a reproducible basis for incident triage. With pre-execution gate integration, unsupported releases could be held while healthy traffic continues under a narrower response scope, reducing potential reserve loss and unnecessary disruption.

FEASIBILITY + VIABILITY

A working replay UI and local reference gate evidence establish prototype feasibility. Adoption starts with read-only validation on one EVM route; public integration, independent evaluation and audited enforcement remain the next milestones.

Submission angle: economic correctness plus auditable operator action.

Submission wording synthesized from the project; expected benefits and business adoption remain hypotheses.

A score you can explain in one sentence.

Example from the seeded key-compromise-and-drain simulation.

THE OBSERVATION

A WETH-route release requests 457 WETH, valued at $1,354,457 in the simulation. Five authorized signers co-sign, but no matching source authorization backs it.

THE CLASSIFICATION

Suspected validator key compromise: valid quorum on an unbacked release. The example also shows lockstep signers and a volume deviation of 12.53.

THE SCORE

Base exploit priority 80 + capped exposure term 15 + campaign term 5 = 100, with evidence completeness 1.0. This is a policy ranking, not a probability.

THE AUTHORITY BOUNDARY

The backing violation supplies the containment basis. Volume and signer behavior add context; a high behavioral score alone cannot authorize a hold.

The alert explains what failed, what is suspected and why it comes first in the queue.

Exact example: detection.json -> detection.example_alert. Synthetic, seed 2410.

A3 / FEASIBILITY UNDER FAILURE

A security tool must know when to abstain.

Planned operational behavior and the remaining trust boundary.

CONGESTION / SOURCE LAG

Delay alone yields pending, overdue or unknown according to observation state. Do not manufacture a missing-deposit exploit from an incomplete source scan.

RPC GAPS / REORGS

Expose coverage health, rebuild affected accounting on canonical changes and suppress advisory scoring when evidence is unresolved. Broader end-to-end scenario evaluation is pending.

LYING OBSERVER

A watermark is an observer assertion, not cryptographic proof of non-deposit. A malicious data source remains a documented limitation until stronger proofs and chain trust are integrated.

GATE OUTAGE / BAD GUARDIAN

A pre-execution delay introduces availability and governance tradeoffs. Define accountable hold/resolve actions and audit them before permitting production authority.

Abstention prevents false certainty; it does not by itself guarantee protection or settlement availability.

Local: reliability contract; PRD trust/non-claims; Eval.tsx scenarios marked pending.

Answers that survive technical scrutiny.

Keep these responses concise, then open the supporting artifact.

IS THIS JUST XCHAINWATCHER?

We reuse and credit its matching principle and data. Our prototype combines the required signals with browser evidence, visible coverage, incident triage and response-policy comparisons; integrated containment remains partly roadmap.

DID YOU PREVENT NOMAD?

No. We replayed the historical dataset. A separate controlled local gate demonstration blocked an unsupported release; counterfactual losses are modeled estimates.

WHY NOT USE AI AS THE DETECTOR?

The reference forest flags only 9/384 held-out attacks at its threshold. Exact accounting supplies the decision; the model is bounded advisory triage with explicit abstention.

CAN IT COVER EVERY BRIDGE?

No. Current semantics cover configured lock/mint and burn/release routes with fixed fees. Liquidity and intent designs require additional adapters and correctness rules.

If asked about production readiness: public feed wiring, stronger trust, independent evaluation and audited gates are still required.

Local: PRD; NON_CLAIMS; model.json; reliability contract; research [S2].

A pitch the team can trace back to evidence.

External context is cited; prototype measurements come from local artifacts.

[S1] HISTORICAL INDUSTRY CONTEXT

Chainalysis, 2 August 2022: Cross-Chain Bridge Hacks Emerge as Top Security Risk. The $2B / 13 hacks / 69% figures are historical context, not current statistics.

[S2] RESEARCH + DATA CREDIT

Augusto et al., XChainWatcher: Monitoring and Identifying Attacks in Cross-Chain Bridges, arXiv:2410.02029. Dataset attribution is retained in the project notices.

LOCAL MEASUREMENT SOURCES

web/src/data/fixtures/{history,detection,evidence,model}.json; generated by web/scripts/build-fixtures.mjs. PRD and HANDOFF describe status and assumptions.

PRESENTATION RULE

Say on this replay, local benchmark, supplied evidence, proposed benefit or modeled loss. Avoid 100% accurate, saved funds, universal prevention or live-mainnet deployment.

Source links and detailed presenter notes accompany the editable deck.

[S1] chainalysis.com/blog/cross-chain-bridge-hacks-2022/ | [S2] arxiv.org/abs/2410.02029